Module 3 Learner Guide: Security Controls and Data Protection Strategies

Start here

This morning you learn the controls that stop or detect the attacks from Day 1, then your team configures them on paper for the fictional RSSO. Nothing today is graded: the workshop is formative, and your team's workbook is recorded as completed.

Item	Detail
Module	3 of 5: Security Controls and Data Protection Strategies
Dates	Face-to-face: Thursday 22 October 2026. Online: Tuesday 27 October 2026
Time	4 hours, 8:00 AM to 12:00 NN (Day 2 morning)
Syllabus items	3.1, 3.2, 3.3
Graded	Nothing. The configuration workshop is formative; completion is recorded
Bring	Your team's Module 2 risk register: today's controls treat those risks

Every control in this guide has two sides: what you do **at your desk**, and what IT sets up **in the server room**. You need to understand both, even if you only do the first.

What you will be able to do

Level	By noon you will be able to	Where you practise
Remember	Recall the Module 3 memory phrases, from Layers, not walls to Roles, not people	Check yourself; desk card
Understand	Explain in plain words what a firewall, an IDS, an IPS and a VPN each do	Lesson 3.1
Apply	Choose the control that stops or detects each Module 2 threat, and the protection for data stored and data moving	Try it 3.1 and 3.2
Analyze	Find separation-of-duties conflicts in a set of roles	Try it 3.3
Evaluate	Score another team's controls for coverage and name the gap that is left	Peer evaluation
Create	Write firewall rules, a role matrix and a data protection plan for the RSSO	Configuration workshop

The morning

Time	Segment
8:00 to 8:15	Recap of Day 1, Quiz 2 results and two risks from your registers
8:15 to 9:00	3.1 Network security principles
9:00 to 9:10	Break
9:10 to 9:50	3.2 Encryption at rest and in transit
9:50 to 10:35	3.3 Zero Trust, MFA and role-based access
10:35 to 10:45	Break
10:45 to 11:45	Configuration workshop (formative)
11:45 to 12:00	Questions; preview of the Module 4 audit and its rules

Your team stays the same as on Day 1. The Module 3 workbook holds the workshop tables; your facilitator gives each team a printed or shared copy.

Lesson 3.1: Network security principles

Key idea: no single control is trusted alone. Put several layers between an attacker and the data, so that when one fails the next one holds: **layers, not walls**.

Layers, like a house

Layer	In a house	At the RSSO
Perimeter	Fence and gate	Firewall at the internet edge
Separate rooms	Locked rooms inside	Network zones (segmentation)
Alarm	Burglar alarm	Intrusion detection and monitoring
A key for each person	Keys only for those who live there	Named accounts, MFA and roles (Lesson 3.3)
Safe	A safe for valuables	Encryption of the database and backups (Lesson 3.2)

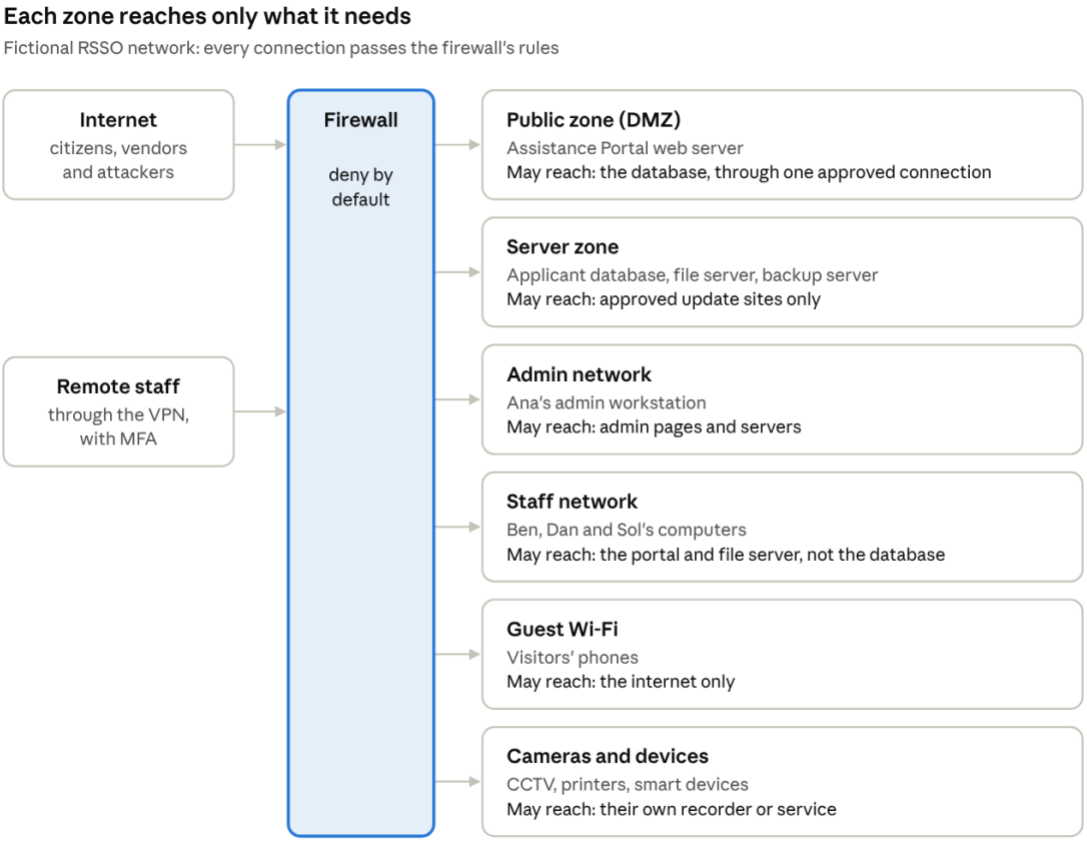
DICT Department Circular 004 (s. 2024) is titled as prescribing a layered security and defense approach for government agencies. Ask your ICT head for its text before you quote any requirement from it.

Separate rooms: segmentation

Split the network into zones, so that a problem in one zone cannot reach the others. **Separate rooms:** each zone reaches only what it needs.

Zone	What sits there	May reach

Zone	What sits there	May reach
Public zone (DMZ)	The Assistance Portal's web server	The applicant database, through one approved connection only
Server zone	Applicant database, file server, backup server	Approved update sites only; nothing else on the internet
Staff network	Staff computers (Ben, Dan, Sol)	The portal and the file server, not the database directly
Admin network	Ana's admin workstation	Admin pages and servers
Guest Wi-Fi	Visitors' phones	The internet only
Cameras and devices	CCTV, printers, smart devices	Their own recorder or service only
Remote access (VPN)	Staff working from home, with MFA	Only what each person's role needs



RSSO network zones · 6 zones behind one firewall, plus the internet and remote staff

Every connection between zones passes the firewall's rules, so a visitor's phone, a camera or one infected staff computer cannot reach the applicant database directly.

Firewalls: the gatekeepers

A firewall checks each connection against a list of rules, then lets it through or blocks it.

Type	What it checks	Plain example
Packet filter	The address and "door number" (port) of each piece of traffic	Only HTTPS may reach the portal
Stateful	Whether traffic belongs to a conversation started from inside	A reply to Ben's request comes back in; a stranger's knock does not
Next-generation	The application and the user, not only the door number	Block file-sharing apps on the staff network
Web application firewall (WAF)	The content of web requests to the portal	Block a login form stuffed with database commands

Rules that work: **deny by default, allow by need, log what you block.**

1. Start from "block everything".
2. Add specific allows: who, to what, using which service.
3. Order matters: the firewall acts on the first rule that matches.
4. Log what is blocked, and have someone review the logs.
5. Filter outbound traffic too: a server that suddenly sends data to an unknown address is a warning sign.

ISO/IEC 27001:2022 covers these in Annex A controls 8.20 (networks security), 8.22 (segregation of networks) and 8.23 (web filtering).

IDS and IPS: the alarm and the guard

IDS tells, IPS stops. An intrusion detection system (IDS) watches traffic or a computer and raises an alert. An intrusion prevention system (IPS) can also block what it finds.

- Network-based systems watch traffic; host-based ones watch a single computer or server.
- Signature-based systems look for known attacks; anomaly-based ones look for unusual behaviour, such as a large transfer at 2:00 AM.
- Both raise false alarms, so IT tunes them. Their logs feed monitoring and, after an incident, the incident report.

VPNs: a private tunnel

A virtual private network (VPN) encrypts the connection between a remote computer and the office.

- A remote-access VPN connects one staff laptop to the office; a site-to-site VPN connects two office networks.
- Every VPN account needs MFA, and the accounts of people who leave are closed on their last day, as Module 2's contractor case showed.

- Split tunneling sends only office traffic through the VPN. It is convenient, but home-network risks then sit next to office access, so IT decides it deliberately.
- Remote desktop is never open directly to the internet; it sits behind the VPN.

At your desk, in the server room

At your desk	In the server room
Use the VPN for office systems when away, and never share your VPN account	Default-deny rules, reviewed on a schedule, with logs watched
Report security alerts and odd behaviour on your computer	Zones that keep guests, devices and staff apart from the servers
Never plug unknown devices into the office network	MFA on VPN and admin accounts; no remote desktop open to the internet

Try it 3.1: Which control stops this? (Apply, 5 minutes, teams)

Match each threat from Module 2 to the control that would stop or detect it: **firewall default deny and an admin network**, **segmentation**, **web application firewall**, **MFA on the VPN**, **segmentation plus an IPS**, **an IDS alert on outbound traffic**.

1. An internet scan finds the portal's admin page.
2. A visitor on guest Wi-Fi tries to open the file server.
3. The portal's login form receives database commands instead of a name.
4. A departed contractor's stolen VPN password is used at night.
5. Malware on one staff computer tries to reach the applicant database.
6. A large amount of data leaves the server for an unknown address over two nights.

Check yourself 3.1

1. What does "layers, not walls" mean?
2. Name three zones a network should keep apart.
3. What is the difference between an IDS and an IPS?
4. Why should a firewall filter outbound traffic too?
5. What two things should every VPN account have?

Lesson 3.2: Encryption at rest and in transit

Key idea: lock, seal, sign. Encryption locks data so only key holders can read it, hashing seals it so any change shows, and a digital signature proves who sent it. Encryption without key management is false comfort.

Three tools, three jobs

Tool	Picture it as	What it protects	RSSO example
Encryption	A locked box: only	Secret	A stolen backup drive cannot

Tool	Picture it as	What it protects	RSSO example
	someone with the key opens it	(confidentiality)	be read
Hashing	A tamper seal: any change breaks it	Correct (integrity), and safe password storage	The portal stores a hash of each password, never the password itself
Digital signature	A signature checked against the signer's public key	Proves who sent it and that it was not changed	A signed payout file shows it came from the RSSO unchanged

Data moving (in transit)

- **Websites and portals:** HTTPS, which uses TLS. The padlock means the connection is encrypted and the site's certificate was issued for that name by a certificate authority. It does not mean the site is honest; Module 4 returns to this.
- **Current versions:** TLS 1.2 or 1.3. TLS 1.0 and 1.1 were formally deprecated in 2021 (RFC 8996).
- **Remote work:** a VPN tunnel (Lesson 3.1).
- **File transfer:** SFTP or HTTPS uploads, never plain FTP, which sends passwords and files unprotected.
- **Wi-Fi:** WPA3, or WPA2-Enterprise with a personal login for each staff member; guests on their own network.
- **Email:** personal data in attachments goes encrypted, or is replaced by a secure link with access control. NPC Circular 2023-06 requires secure transmission for emails that carry personal data.

Data stored (at rest)

- **Laptops and phones:** full-disk encryption, so a lost device does not mean lost data.
- **Databases and files:** database or file-level encryption for sensitive personal information.
- **Removable media:** office-issued encrypted USB drives only. NPC Circular 2023-06 requires encryption when personal data must move on removable media.
- **Backups:** encrypted, with at least one copy kept offline.

Keys: the part people forget

Question	What the RSSO decides
Who holds the key?	A named key custodian, for example Ana, with a backup custodian
Where is it kept?	Apart from the data it protects, never on the same drive or server
Who can recover it?	Through a sealed recovery procedure approved by the head of office
When does it change?	On a schedule, and at once when a custodian leaves or a key may be exposed

Memory phrase: **moving, stored, keys.** Protect data while it moves, while it is stored, and protect the keys.

What the DPA and the NPC expect

- **NPC Circular 16-03, Section 7:** security measures may include backup solutions, access control and secure log files, encryption, and a data disposal and return-of-assets policy.
- **NPC Circular 2023-06:** encrypted removable media when that transfer is unavoidable; secure transmission of emails with personal data; and multi-factor authentication or secure encrypted links for online access to sensitive personal information, privileged information and large volumes of personal data.
- **DPA Section 23:** approved off-site access to government-held sensitive personal information uses the most secure encryption standard the NPC recognizes, at most 1,000 records at a time.

At your desk, in the server room

At your desk	In the server room
Lock your screen; keep work files on approved, encrypted storage	Full-disk encryption on every laptop; encrypted database and backups
Use only office-issued encrypted USB drives, with approval	TLS 1.2 or 1.3 on the portal; old versions and plain FTP turned off
Share personal data by secure link, never as a plain attachment	Keys kept apart from data, with a named custodian and a recovery plan

Try it 3.2: Encrypt it right (Apply and Evaluate, 10 minutes, teams)

For each fictional RSSO data set, choose its protection when stored and when moving, and name who holds the key.

1. The HR shared drive with staff records
2. A USB drive field staff use to bring home-visit forms to the office
3. The nightly database backup
4. A data exchange between the RSSO's system and a partner agency's system
5. A mobile app social workers use on field visits
6. Scanned IDs and medical certificates uploaded by applicants
7. A list of payouts sent to the e-wallet provider
8. The public Assistance Portal

Optional, if devices allow: click the padlock on any public government website and look at who issued its certificate and when it expires. Never do this with a page that shows real personal data.

Check yourself 3.2

1. Which tool protects Secret, which protects Correct, and which proves who sent a file?
2. What does the padlock in the address bar tell you, and what does it not tell you?
3. Name two places where stored data must be encrypted.

4. Why must keys be kept apart from the data they protect?
5. What does NPC Circular 2023-06 require when personal data must go on a USB drive?

Lesson 3.3: Zero Trust, MFA and role-based access

Key idea: never trust, always verify. Being inside the office network proves nothing. Every request to reach data is checked: who you are, from which device, and whether your role needs it.

Zero Trust in four habits

Habit	Plain meaning	At the RSSO
Verify every request	Check identity and device each time, not once at the door	Ben's login is checked with MFA even inside the office
Assume breach	Plan as if an attacker is already inside	Zones and logs limit how far a stolen account can go
Least privilege	Give only the access the job needs, only for as long as it is needed	Dan sees payout details, not health records
Keep checking	Watch for unusual behaviour and re-check access	A login from an unusual place is blocked and reviewed

Zero Trust is a strategy, not a product you buy. NIST Special Publication 800-207 sets out its principles: every resource is protected, all communication is secured whatever the network location, and access is decided for each request by policy.

First steps for an office: list its people, accounts and devices; turn on MFA first for email, VPN and admin accounts; separate the network into zones; keep logs and look at them; review access on a schedule.

MFA: know, have, are

Multi-factor authentication asks for two or more kinds of proof: something you **know** (a password or PIN), something you **have** (a phone or a security key), and something you **are** (a fingerprint or face).

Method	Strength	Why
Code by SMS or voice call	Better than a password alone	Codes can be stolen through SIM swaps and fake login pages
Code in an authenticator app; push with number matching	Stronger	Number matching blunts MFA fatigue, but CISA calls it an interim step
Security key or passkey (FIDO2)	Strongest: resists phishing	A fake page cannot use it, because the key checks the real site's address

CISA strongly urges phishing-resistant MFA, based on FIDO/WebAuthn or PKI (31 October 2022). If a sign-in prompt appears that you did not start, deny it and report it.

Passwords that work

- Long beats complex: a passphrase of four or more unrelated words.
- One password per account, kept in a password manager.
- Never reuse an office password anywhere else.
- Pwned Passwords checks whether a password has appeared in known breaches without sending it: only the first 5 characters of the password's hash are sent, never the password itself. In class we use invented passwords only.

Roles, not people

Role-based access control (RBAC) gives access to roles that match job functions, and people are given roles, not one-off permissions: **roles, not people**.

- **Least privilege:** each role gets only what the job needs.
- **Two hands on money:** separation of duties means no one person can both create and approve a payout, or change an e-wallet number and release the payment.
- **Joiner, mover, leaver:** access is set up on the first day, changed on transfer, and closed on the last day, including for contract-of-service and job-order staff and consultants.
- No shared accounts, least of all admin accounts. Admins use a separate admin account, only for admin work.
- Access is reviewed every quarter, and every privileged action is logged.

ISO/IEC 27001:2022 covers these in Annex A controls 5.15 to 5.18 (access control, identity management, authentication information, access rights), 8.2 (privileged access rights) and 8.5 (secure authentication). NPC Circular 2023-06 requires an access control policy, a security clearance filed with the DPO for those who may access personal data, and a password policy.

At your desk, in the server room

At your desk	In the server room
Turn on MFA wherever it is offered; deny prompts you did not start	MFA first on email, VPN and admin accounts; security keys for admins
Never share your login, not even with your supervisor	Roles that match job functions; separate admin accounts
Tell IT the day someone joins, moves or leaves	Quarterly access reviews; a log of every privileged action

Try it 3.3: Design the roles (Create and Analyze, 10 minutes, teams)

The RSSO Assistance Portal has four roles: records clerk, supervisor, cashier and system administrator. Decide which role gets each function, then find the conflicts.

Functions: encode a new application; view applicant records; approve an application; edit an applicant's e-wallet number; release a payout; create and disable user accounts; view audit logs; export applicant data.

1. Which pairs of functions must never sit with one person?
2. Ana is the only system administrator. What risk does that create, and what is one control?
3. A clerk is promoted to supervisor. What must happen to her clerk access?

Check yourself 3.3

1. What does "never trust, always verify" mean for a login from inside the office?
2. Name the three kinds of proof that MFA can use.
3. Why does a security key resist phishing when an SMS code does not?
4. What is separation of duties? Give one RSSO example.
5. What are the three steps of joiner, mover, leaver?

Configuration workshop (formative, 60 minutes)

Key idea: your team hardens the fictional RSSO Assistance Portal on paper, using this morning's controls. No command line is needed. Completion is recorded; nothing is scored.

Part	Minutes	What your team does	Output in the workbook
Brief	5	Read the network and the three tasks	None
Task A, perimeter	15	Write firewall rules with a default-deny stance, then test them against six sample connections	Rule table and self-check
Task B, access	15	Give four roles their functions, set the MFA policy, and list the joiner, mover and leaver steps	Role matrix, MFA policy, three checklists
Task C, data protection	15	Classify six data sets, choose protection when stored and moving, name a key custodian, and set backup rules	Data protection table and backup rules
Peer evaluation	10	Swap workbooks with another team and score each control from 1 to 3	Scorecard with the gap left

Peer evaluation scale: **3** covers the risk; **2** partly covers it; **1** leaves a gap. For every 1 or 2, write down the gap that is left.

Tips:

- Start each task from your Day 1 risk register: which of your risks does this control treat?
- In mixed teams, non-IT members often know best who should see what (Task B), and IT members help word the rules (Task A).
- Rotate roles from Day 1: facilitator, scribe, timekeeper, reviewer.
- The usual mistakes: "allow any" rules, shared admin accounts, and backups that were never restored.
- Your role matrix comes back this afternoon: in Module 4 you compare the RSSO portal's role table with it.

Face-to-face, your team works on the printed workbook at its table. Online, your team works in its own shared copy, in its breakout room.

Desk card: Module 3 additions

Add these to your Day 1 desk card.

Remember	What it means	What you do
Layers, not walls	Several controls, so one failure is not a disaster	Never rely on a single control, however strong
Separate rooms	Network zones keep guests, devices, staff and servers apart	Keep personal devices and visitors off the office network
Deny by default	Block everything, allow by need, log what is blocked	Ask IT for what you need instead of using a workaround
IDS tells, IPS stops	Detection raises an alert; prevention also blocks	Report security alerts at once
Lock, seal, sign	Encryption, hashing, digital signatures	Use encrypted storage and secure links for personal data
Moving, stored, keys	Protect data in transit, at rest, and the keys	Never keep a password or key with the data it protects
Never trust, always verify	Zero Trust: check every request, assume breach, least privilege	Expect MFA even inside the office
Know, have, are	The three kinds of MFA proof	Turn MFA on; deny prompts you did not start
Roles, not people	Access by job function; two hands on money; joiner, mover, leaver	Never share a login; report joiners, movers and leavers

Glossary additions

Term	Plain meaning
Certificate	A site's digital ID, issued by a certificate authority, that lets your browser check it is talking to the right site
Digital signature	A mark made with a private key that proves who sent a file and that it was not changed
DMZ (public zone)	The part of a network that holds public services, kept apart from internal systems
Encryption	Scrambling data so only someone with the key can read it

Term	Plain meaning
FIDO2, passkey, security key	Sign-in methods based on a key held on your device, which a fake site cannot use
Firewall	A gatekeeper that allows or blocks connections according to rules
Hashing	Turning data into a fixed fingerprint; any change gives a different fingerprint
IDS, IPS	Systems that detect suspicious activity and alert (IDS), or also block it (IPS)
Key custodian	The person responsible for keeping, and recovering, an encryption key
Least privilege	Giving only the access a job needs, only for as long as it is needed
MFA	Multi-factor authentication: signing in with two or more kinds of proof
RBAC	Role-based access control: access given to roles that match job functions
Segmentation	Dividing a network into zones that each reach only what they need
Separation of duties	Splitting a task so no one person can complete a risky action alone
TLS	The protection behind HTTPS that encrypts data moving between a browser and a site
VPN	An encrypted tunnel between a remote computer and the office network
WAF	A web application firewall, which inspects requests sent to a website
Zero Trust	A strategy of checking every request, assuming breach, and granting least privilege

Answers

Model answers: a different answer with a sound reason can also be right.

Lesson 3.1

Try it 3.1: 1. Firewall default deny and an admin network: the admin page answers only on the admin network. 2. Segmentation: guest Wi-Fi reaches only the internet. 3. A web application firewall, while the vendor fixes the form itself; Module 4 adds the buying habit of asking for proof of security testing. 4. MFA on the VPN, and accounts closed on the last day. 5. Segmentation plus an IPS: staff computers cannot reach the database directly, and the IPS blocks the attempt. 6. An IDS alert on outbound traffic, with outbound filtering that allows only approved destinations.

Check yourself: 1. Several controls, so that when one fails the next one holds. 2. Any three of: public zone (DMZ), server zone, staff network, admin network, guest Wi-Fi, cameras and devices. 3. An IDS detects and alerts; an IPS can also block. 4. To catch data leaving, and malware calling out to an attacker. 5. MFA, and closure when the person leaves.

Lesson 3.2

Try it 3.2

Data set	Stored	Moving	Key holder
1. HR shared drive	Drive or file encryption; access by role only	Encrypted file sharing inside the office; VPN from outside	Ana, with access approved by the HR head
2. Field USB drive	Office-issued encrypted USB drive	Hand-carried with the head's approval; at most 1,000 sensitive records	The field supervisor, with Ana as backup
3. Nightly backup	Encrypted, with one copy offline	Encrypted transfer to the backup location	Ana, with a sealed recovery copy
4. Partner agency exchange	Each agency's own encrypted database	TLS with both sides authenticated, under a data sharing agreement	Each agency's IT, named in the agreement
5. Social workers' app	Device and app encryption; remote wipe if lost	TLS to the office server	IT, through device management
6. Scanned IDs and certificates	Encrypted storage, open only to staff who check applications	HTTPS upload	Ana
7. Payout list	Encrypted file, deleted from staff computers after upload	The provider's business portal over HTTPS instead of email; if email cannot be avoided, an encrypted file with the password sent another way	Dan for the file; Ana for the system
8. Public	No sensitive data kept on	HTTPS with TLS 1.2 or 1.3 and a	Ana, renewing

Data set	Stored	Moving	Key holder
portal	the web server itself	valid certificate	certificates before they expire

Check yourself: 1. Encryption; hashing; digital signature. 2. The connection is encrypted and the certificate matches the site's name; it does not prove the site is honest. 3. Any two of: laptops and phones, databases, removable media, backups. 4. Whoever steals both can read everything. 5. The drive must be encrypted.

Lesson 3.3

Try it 3.3

Function	Records clerk	Supervisor	Cashier	System administrator
Encode a new application	Yes	No	No	No
View applicant records	Assigned cases	Yes	Payout details only	No
Approve an application	No	Yes	No	No
Edit an e-wallet number	Yes, after a call-back check	No	No	No
Release a payout	No	No	Yes	No
Create and disable user accounts	No	No	No	Yes, approved by the head of office
View audit logs	No	Read only	No	Read only; the DPO also reads them
Export applicant data	No	With written approval	No	No

1. Encode and approve; edit an e-wallet number and release the payout; manage accounts and approve or pay; change the logs and act in the system.
2. One person with unchecked power, and nobody to fix things when she is away. Controls: a second trained administrator, logs sent where Ana cannot change them, and a sealed emergency account.
3. It is removed on the day she moves (the mover step), so she cannot encode and approve the same application.

Check yourself: 1. It is checked like any other request, for identity, device and need; being inside proves nothing. 2. Something you know, something you have, something you are. 3. The key checks the real site's address and will not sign in to a fake page; an SMS code can be typed into a fake page. 4. Splitting a task so no one person can complete it alone; for example, whoever edits an e-wallet number cannot release the payout. 5. Set up access on the first day, change it on transfer, close it on the last day.

Where each fact comes from

Every fact in this guide was checked on 20 October 2026. This is training material, not legal advice.

- ISO/IEC 27001:2022 Annex A control names: Open Security Architecture
- DICT Department Circular 004 (2024), title only: National Administrative Register
- TLS 1.0 and 1.1 deprecated: RFC 8996, March 2021
- NPC Circular 16-03, Sections 6 and 7: National Privacy Commission
- NPC Circular 2023-06 requirements: Baker McKenzie summary, 19 April 2024; NPC announcement
- DPA Section 23: RA 10173
- Zero Trust principles of NIST SP 800-207: NetScout explainer
- Phishing-resistant MFA and number matching: Infosecurity Magazine on CISA's guidance, 1 November 2022
- Pwned Passwords and k-anonymity: Troy Hunt